Texas Children's Hospital
Ransomware Policy

Texas Children's Hospital
Ransomware Policy and Playbook Manual

Subject: Ransomware Policy
Version: 1.0
Approved: Myra Davis
Effective: 10/4/2025

---

1. Introduction and Policy Statement

Purpose: This policy defines the formal principles, rules, standards, responsibilities, and procedural framework for preventing, detecting, containing, and recovering from a ransomware attack. The primary objective is patient safety and continual, uninterrupted care delivery. The secondary objective is protecting Protected Health Information (PHI) in compliance with all applicable federal (HIPAA, HITECH) and Texas regulations.

Policy Statement: Incident prevention, preparation, and detection is at the forefront of our cybersecurity implementation at Texas Children's. In the event of an attack, the hospital's highest priority is to ensure patient safety and clinical workflow continuity. The next highest priority is network isolation, data restoration from secure backups, and to fulfill all compliance measures such as mandatory breach notification requirements. Texas Children's strongly discourages the payment of ransom, and it should only be considered as an absolute last resort. If a ransom is to be paid, it must be authorized by the Executive Incident Response Team (detailed in the Texas Children's Cybersecurity Policy Manual) and legal counsel consultation.

Scope and Applicability: This policy applies to all personnel (employees, medical staff, contractors, volunteers, and business associates) who access the hospital's data, systems, or PHI for the purpose of processing, storing, or transmitting regardless of location (on-premises, remote, or cloud-based).

2. Governance and Compliance

The structure of this playbook is based on the NIST SP 800-61 Rev. 2 [1] and is integrated with the hospital's overall HIPAA Security Rule compliance program [2].

2.1 Governance Structure and Roles

Four core governance authorities serve as our governance leadership and executors in order to ensure consistent threat monitoring, early detection, and system resiliency in the case of incidents.

ROLE	RESPONSIBILITY/ACTION
Chief Information Security Officer (CISO)	Policy ownership, security program management, and chair of the Core Incident Response Team (IRT).
Core Incident Response Team (Core IRT)	Technical execution of the Incident Response Plan [1]. Includes IT Security, IT Operations, and Forensics specialists.
Executive IRT (EIRT)	Strategic decision-making body (CEO, CIO, CPO, General Counsel, Communications). Sole authority for authorizing network shutdown, engaging external counsel, and approving any potential ransom payment.
Chief Privacy Officer (CPO)	Primary authority on HIPAA and HITECH compliance [2, 3], breach risk assessment, and mandatory regulatory reporting (HHS-OCR, Texas AG) [4].

2.2 Legal and Regulatory Compliance

A ransomware attack that results in the encryption of unsecured Electronic Protected Health Information (ePHI) is considered a HIPAA violation unless the hospital can demonstrate a low probability that the ePHI was compromised [3].

REGULATION	TRIGGER/ THRESHOLD	NOTIFICATION TIMELINE	RECIPIENT
HIPAA/HITECH	Breach of Unsecured ePHI	No later than 60 days after discovery.	Affected Individuals, HHS Office for Civil Rights (OCR), and Media (if >500 individuals).
Texas Law (B&C Code § 521.053)	Breach affecting 250 or more Texans.	As soon as practicable, but no later than 30 days after discovery.	Texas Attorney General (OAG), electronically via mandated form.
Texas Law (Individual)	Breach affecting any Texas resident.	Most expedient time possible and without unreasonable delay.	Affected Individuals.

Compliance with the HIPAA notification requirements generally satisfies the Texas state law for notifying Texas residents. However, the Office of the Attorney General must be notified if 250 or more Texans are affected and within 30 days of discovery [4]. This is a shorter reporting limit than HIPAA's 60-day limit.

3. Identification

3.1 Asset Inventory and Critical Tiers

A current, verified inventory of all hardware, software, and data repositories is mandatory for effective incident response. Assets must be classified and assigned an RTO (Recovery Time Objective) and RPO (Recovery Point Objective).

Tier	Description	Examples	Recovery Time Objective	Recovery Point Objective
Tier 0 (Life Critical)	Direct impact on patient safety and clinical functions. **Highest Priority.**	EHR/EMR, PACS, Biomedical Systems, Anesthesia Systems.	4 Hours	1 Hour
Tier 1 (Core Operations)	Essential for business operations and regulatory requirements.	Patient Scheduling, Billing/ADT, Enterprise Email, Identity Management (AD).	24 Hours	4 Hours
Tier 2 (Support Functions)	General administration and non-essential services.	HR/Payroll, Public Website, Internal SharePoint/ Collaboration.	72 Hours	24 Hours

3.2 Vulnerability and Risk Management

All Tier 0 and Tier 1 systems should be performed monthly. Any critical vulnerabilities must be patched within 7 days of discovery.

The CISO should conduct comprehensive, threat-based risk assessments for ransomware attack vectors quarterly. Texas Children's also seeks to decrease our recovery time for both Tier 1 and 2 operations through CISO-led strategies paired with Core IRT training to increase resiliency preparedness for core and support operations.

4. Protection and Prevention

In-depth defense is mandatory to protect the hospital's critical infrastructure. These requirements are managed and iterated on by the CISO. All employees are responsible for meeting governance standards when interacting with hospital technology.

4.1 Preventative Measures (Technical)

- Multi-Factor Authentication -- > Mandatory for all remote access (VPN) and access to all critical systems like EHR/EMR, privileged accounts and cloud services [6].
- Network Segmentation --> Utilize VLANs and firewalls to separate clinical patient care networks, administrative networks, and research networks. Critical EMR/ePHI servers must be segmented from the general corporate network.
- Patch Management --> Implement a patching schedule that prioritizes operating systems, web browsers, and applications with known vulnerabilities.
- Email Security --> Enforce strong spam filtering, blocking known malicious file extensions and implementing Domain-based Message Authentication, Reporting and Conformance.
- Principle of Least Privilege --> Restrict all user and service accounts to minimum access required to perform their jobs. Local administrator rights should be prohibited for standard clinical and administrative users.

4.2 Preventative Measures (Personnel)

- Mandatory Training --> All personnel must complete mandatory annual cybersecurity awareness training. This should include simulation exercises like phishing and social engineering.
- Phishing Simulations --> Quarterly phishing simulation tests should be conducted and remedial training provided immediately for users who fail.

4.3 Backup and Recovery

1. Strategy --> Implement the 3-2-1 Backup Rule (3 copies of data, 2 different media types, and 1 copy offsite/air-gapped) [7].
2. Air-Gapped/Immutable Backups --> Critical ePHI and system images must be stored on immutable, air-gapped media (offline tapes, write-once cloud storage) that cannot be encrypted or deleted by network-based ransomware.
3. Testing --> Conduct regular full system restoration tests of Tier 0 and Tier 1 systems from backups to validate recovery time objectives and recovery point objectives.

5. Detection

5.1 Monitoring and Logging

Comprehensive logging must be enabled and centrally collected via a Security Information and Event Management (SIEM) system [1]. Critical systems and all endpoints, and network perimeters and internal firewalls should enable logging. The IT Security Team (part of Core IRT)

must establish rules within the SIEM to alert for any Ransomware Indicators of Compromise. Specific indicators include but are not limited to:

- Mass file renaming, deletion, or modification in a short amount of time.
- Unusual internal Remote Desktop Protocol or lateral movement between segregated subnets.
- Suspicious outbound connects to known Command and Control servers.

5.2 Reporting Procedures

If any personnel detects or suspects ransomware infection, they should immediately report the incident and perform initial self-isolation.

ROLE	RESPONSIBILITY/ACTION
End User	Immediately report suspicious activity (pop-up, encrypted file extension, system slowdown) via the designated channel (e.g., IT Security Hotline, internal ticketing). Disconnect device from the network.
IT Operations	Triage incoming reports; Validate the incident type (Ransomware). Log all initial details (User, asset tag, IP, time, visual screen data). Physically isolate the host.
IT Leadership	Immediately notify the Senior Business Leadership/Executive IRT and the Chief Compliance/Privacy Officer.
Chief Privacy Officer	Begin initial assessment of whether ePHI may be involved to determine if a HIPAA/Texas breach investigation is required.

6. Response and Recovery

The incident response is based on the recommended phased approach defined by NIST SP 800-51 Rev.3 [1].

6.1 Containment Phase

ACTION	RESPONSIBILITY	TIMING	NOTE
1. Isolate Infected Host(s)	IT Operations/Security	Immediate	Disconnect network cable or disable Wi-Fi. Do not power down unless isolation is impossible (preserves volatile memory for forensics).
2. Emergency Core Isolation	IT Leadership/Network Ops	10 Minutes	Implement predefined access control lists on core switches to block traffic between critical subnets (EMR/PACS) and the general user network.

3. Halt/Disconnect Backups	IT Operations/Backup Admins	15 Minutes	Immediately physically disconnect or logically isolate online backup appliances to prevent encryption. Verify cold/air-gapped backups are secure.
4. External Connectivity Stop	IT Leadership/Network Ops	30 Minutes	Severe all non-essential external connections (e.g., vendor VPNs, remote access), or apply firewall rules to block suspicious outbound traffic.
5. Activate Clinical Downtime	Senior Business/Clinical Ops	60 Minutes	Clinical leadership initiates paper-based, manual operations across affected departments (e.g., Pharmacy, Labs, ORs).

Clinical Downtime Procedures: All departments (clinical and administrative) must maintain Downtime Procedures (detailed in the Texas Children's Power Outage Policy Manual). Staff should immediately access Downtime Kits (paper charts/forms, clipboards, emergency phone lists). All staff should regularly train in the manual processes for:

- Medication administration/Verification (MARs)
- Order entry and lab results
- Patient identification and registration
- Life support systems and biomedical device operation

6.2 Eradication Phase

ROLE	RESPONSIBILITY/ACTION
IT Operations	Complete the wiping of all infected assets. Forcibly reset credentials for all potentially compromised accounts, starting with privileged accounts and service accounts.
IT Security	Close all backdoors identified by the Forensics Team. Apply temporary preventative measures (e.g., blocking all executable files in user profiles) before system restoration.
HR/Supervisors	Document personnel actions related to the incident, including any disciplinary action for policy violation (e.g., misuse of privileges, failure to report suspicious activity).

6.3 Recovery Phase

All assets must be restored within their respective tier's requirements as designated in Section 3.1.

ROLE	RESPONSIBILITY/ACTION
IT Operations/ Backup Admins	Restore systems from verified, clean, air-gapped backups to a clean, isolated network segment. Restore Tier 1 systems first (EHR/EMR, PACS, clinical systems).
Clinical Leadership	Coordinate the safe return to electronic operations department-by-department. Conduct integrity checks on clinical data post-restoration.

Chief Compliance Officer	Coordinate all mandatory regulatory reporting as required by the breach assessment.
Customer Service	Implement the pre-approved customer notification scripts under the direction of the Executive IRT and Legal Counsel.

7. Post-Incident Activity and Notification

The Chief Privacy Officer and legal counsel should determine the necessary breach notification requirements based on the forensic evidence of the attack. Any affected individuals should be notified within the mandatory timeline [3]. Texas requires that the Texas Attorney General's office must be notified no later than 30 days post attack if more than 250 Texans were affected [4].

A full attack postmortem should be conducted and evaluated by all members of the core governance authorities established in Section 2.1 to review the root cause analysis. Based on the findings, long-term security enhancements should be implemented, and staff training should be revised accordingly.

References

1. Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile* (NIST Special Publication 800-61 Revision 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3
2. Health Insurance Portability and Accountability Act of 1996, 42 U.S.C. § 1320d et al.; 45 C.F.R. Parts 160 and 164 (2003). https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C
3. Health Information Technology for Economic and Clinical Health Act, Pub. L. No. 111-5, § 13001 et seq., 123 Stat. 226 (2009). https://www.congress.gov/111/plaws/publ5/PLAW-111publ5.pdf
4. Tex. Bus. & Com. Code Ann. §§ 521.001–.152 (2009). https://statutes.capitol.texas.gov/docs/bc/htm/bc.521.htm
5. Cybersecurity and Infrastructure Security Agency. (n.d.). *Healthcare and Public Health Sector*. CISA. https://www.cisa.gov/stopransomware/healthcare-and-public-health-sector
6. Twosense. (n.d.). *First major HIPAA update in nearly 20 years: What hospitals need to know about MFA*. https://www.twosense.ai/blog/hipaa-security-rule-update
7. Cybersecurity and Infrastructure Security Agency. (2025, August 29). *Level Up Your Defenses—Five Cybersecurity Best Practices for SLTTs*. CISA.gov. https://www.cisa.gov/resources-tools/resources/level-your-defenses-five-cybersecurity-best-practices-sltts
8. National Motor Freight Traffic Association. (2022, November). *Ransomware Playbook Template*. https://nmfta.org/wp-content/media/2022/11/Ransomware-Playbook-Template.pdf

To: Myra Davis (CIO) & Gordon Groschl (CISO)
From: Group 49
Date: 10/4/2025
Subject: Ransomware: Delivery Methods, Frequency, and Impacts for Texas Children's Hospital

---

Introduction

Ransomware attacks on healthcare cause a domino effect of serious and dire consequences. Like many other places, healthcare is susceptible to data breaches and financial loss; however, the stakes are significantly higher when patient care and safety are at risk. Healthcare disruptions can cause delays in medical treatment and in the worst case, can result in loss of lives. The first recorded ransomware attack on healthcare was in 1989 where a Trojan horse was sent to AIDS researchers demanding ransom in exchange for their data. Now, with the exponential development of technology, attacks have only grown to be more rampant, dangerous, and costly. [1]

Nature of Ransomware

Ransomware is a form of malicious software designed to deny access to data or a computer system until money is paid. In most cases, ransomware encrypts critical files or entire systems, rendering them unusable to authorized users. Once access is blocked, attackers demand payment - typically in cryptocurrency - in exchange for a decryption key. In some cases, payment does not guarantee data recovery or system restoration, leaving organizations with significant financial and operational damages. The primary objectives of ransomware are extortion and disruption. However, in the healthcare sector, the consequences extend beyond monetary loss or reputational harm. Attackers exploit the urgency and life-critical nature of medical operations, knowing that hospitals and healthcare providers are more likely to pay quickly to resume patient care. This has made healthcare one of the most targeted industries for ransomware. [1]

In recent years, ransomware tactics have evolved significantly. Recent triple extortion adapts newer tactics not only encrypts and exfiltrates data but also applies pressure through additional channels - such as contracting patients, vendors, or launching distributed denial-of-service (DDoS) attacks. High-profile ransomware incidents like Conti (2021-2022), which targeted numerous US hospitals, highlight the devastating potential of these attacks. These campaigns disrupted emergency care, delayed surgeries, and exposed patient data while costing millions in remediation and recovery. [7]

In Texas several regional medical centers have reported incidents over the last few years, illustrating that both urban hospitals and rural clinics remain vulnerable. [10] Attackers often exploit outdated systems, weak remote access controls, or unsuspecting users through phishing emails, making it clear that proactive defense is essential. Ransomware continues to evolve as a persistent, sophisticated threat, especially to the healthcare sector. Understanding its nature is the

first step in developing a comprehensive defense strategy that safeguards data and the lives of patients who depend on uninterrupted care. [3][4][7]

Delivery Methods / Attack Vectors

Ransomware typically enters the hospital system through several well-known attack vectors, each exploiting either technical weakness or human behavior. Understanding these methods is essential to building effective defense strategies.

One of the most common entry points is phishing, where attackers send deceptive emails that trick staff into clicking malicious links or opening infected attachments. In a high-pressure hospital environment, this method is especially effective. Mitigations include advanced email filtering, disabling macros, user awareness training, and enforcing multi-factor authentication (MFA). [3]

Another major vector is the exploitation of unpatched software vulnerabilities. Attackers take advantage of outdated systems, including legacy medical devices, to gain access. Internet of Medical Things (IoMT) and medical devices are often running outdated or using default credentials, making them easy targets. These devices must be segmented from other networks, monitored for unusual activity, and managed in coordination with vendors for timely updates. [5]

Remote Desktop Protocol and other remote access services are frequently targeted through brute-force attacks or stolen credentials. Hospitals often rely on third- party vendors and remote clinicians, increasing exposure. Cloud misconfigurations and stolen cloud credentials are a growing threat. Poorly secured cloud storage or administrative accounts can lead to data breaches or ransomware deployment. [1] Mitigations include disabling unused RDP, requiring VPN with MFA, and restricting access to authorized IPs. Malvertising and drive-by downloads can also introduce ransomware when users visit compromised websites or click infected ads. This is especially dangerous on critical workstations. [6] Infected USB drives or external hard drives could also be used. Hospicals should enforce device control policies and require media scanning, and limit the use of removable storage. [9]

Across all vectors, hospitals must implement cross-cutting protections including regular, offline backups; endpoint detection and response (EDR); principle of least privilege and incident response plans that address ransomware scenarios. Building a layered defense is essential for data protection and maintaining patient safety and uninterrupted care delivery. [3][4]

To: Myra Davis (CIO) & Gordon Groschl (CISO)
From: Group 49
Date: 10/4/2025
Subject: Ransomware: Delivery Methods, Frequency, and Impacts for Texas Children's Hospital

---

Frequency of Attacks

The number of ransomware attacks has continued to increase over the years, nearly doubling from 2022 to 2023. [1] Every sector of healthcare, including hospitals and research institutions, is frequently targeted by trained and well-equipped attackers. From technical vulnerabilities to social engineering, cybercriminals exploit any weakness to gain access to sensitive data. As ransomware continues to advance in both methods and capabilities, it is crucial that all sectors of healthcare strengthen their defenses and follow standard security procedures to prevent such attacks.

Specific Exploits and Impacts

A notable ransomware attack was the WannaCry attack in 2017, which affected over 200,000 computers across 150 countries. The attackers exploited a zero-day vulnerability originally developed by the National Security Agency (NSA), which was later stolen and used to launch the attack. This incident severely disrupted the United Kingdom's National Health Service (NHS), resulting in widespread appointment and surgery cancellations. [2]

Another example is the attack on Change Healthcare, a subsidiary of UnitedHealth Group responsible for processing billions of health records, including patient data, payment information, and insurance claims. In this case, approximately 6 TB of data was encrypted by the hacker group BlackCat/ALPHV, who gained access through compromised credentials and demanded a $22 million ransom payment. [3]

Conclusion

Defending against ransomware is not just a technical challenger, but a patient safety imperative. By understanding the threat, addressing vulnerabilities, and building resilient systems, healthcare organizations can better protect their data, operations, and the patients who rely on uninterrupted, secure care.

As ransomware tactics continue to evolve, the healthcare sector's approach must evolve in parallel to multi-layered defense. The hospital's ransomware policy provides a clear, proactive, and multi-layered security strategy that includes regular patching, strong access controls, user training, and tested incident response plans, which are no longer optional but essential.

To: Myra Davis (CIO) & Gordon Groschl (CISO)
From: Group 49
Date: 10/4/2025
Subject: Ransomware: Delivery Methods, Frequency, and Impacts for Texas Children's Hospital

---

References

1. Office of the Director of National Intelligence. (2024, February 28). *Ransomware attacks surge in 2023; attacks on healthcare sector nearly double* [PDF]. CTIIC. https://www.dni.gov/files/CTIIC/documents/products/Ransomware_Attacks_Surge_in_2023.pdf
2. Cloudflare, Inc. (2025). What was the WannaCry ransomware attack? Retrieved from https://www.cloudflare.com/learning/security/ransomware/wannacry-ransomware/
3. American Hospital Association. (2025, January). *Change Healthcare cyberattack underscores urgent need to strengthen cyber preparedness* [PDF]. https://www.aha.org/system/files/media/file/2025/02/Change-Healthcare-Cyberattack-Underscores-Urgent-Need-to-Strengthen-Cyber-Preparedness.pdf
4. Cybersecurity & Infrastructure Security Agency. (2023, October). *Stop ransomware guide* [Web page]. https://www.cisa.gov/stopransomware
5. U.S. Department of Health and Human Services. (2023, August). *HC3 ransomware trends in healthcar*e [Web page]. https://www.hhs.gov/about/agencies/asa/ocio/hc3/index.html
6. Verizon. (2023). 2023 *Data breach investigations report (DBIR)* [Report]. https://www.verizon.com/business/resources/reports/dbir/
7. Microsoft. (2023, October). *Microsoft digital defense report 2023* [PDF]. https://www.microsoft.com/en-us/security/business/security-intelligence-report
8. IBM Security. (2023). *X-Force threat intelligence index 2023* [PDF]. https://www.ibm.com/reports/threat-intelligence
9. National Institute of Standards and Technology. (2021). *NIST SP 1800-30: Securing telehealth remote patient monitoring ecosystem* [Special Publication]. https://www.nccoe.nist.gov/projects/building-blocks/secure-telehealth
10. CBS19. (2024, October 3). *Security incident that caused network outages at UT Health East Texas identified as ransomware attack*. https://www.cbs19.tv/article/news/local/security-incident-that-caused-network-outages-ut-health-east-texas-identified-as-ransomware-attack/501-7c011a0a-fe81-4235-bb01-c86fa3acefff